

ERP/1: Авторизація

Політики

Технічних вимог, Техноробочого проекту
і Технічної документації

Зміст

Зміст

Анотація

У статті подаються універсальні засади політик проектів для державних ІТ підприємств, типовий зміст технічних вимог з повною таксономією підрозділів та структурою технічного завдання відповідно до ДСТУ. Показані принципи, як політики визначають вимоги, що узгоджують технічне завдання та посилання на ключові державні стандарти документування ДСТУ. Матеріал призначений для архітекторів, аналітиків та розробників, які працюють над державними та комерційними проектами в Україні.

1. Політики

Політики є первинним і незмінним документом будь-якого проєкту. Вони визначають правила гри до того, як формулюються вимоги чи обираються технології.

Умовні скорочення та визначення

Терміни та скорочення, що використовуються в документі:

Термін	Значення
ТВ	Технічні вимоги
ТЗ	Технічне завдання
ТД	Технічна документація

Загальні принципи

1. Політики є первинними документами.
2. Усі рішення в проєкті приймаються виключно на основі затверджених політик.
3. Технічні вимоги формуються виключно як похідні від політик.
4. Технічне завдання є єдиним документом, де дозволяється вказувати конкретні продукти.
5. Архітектура повинна залишатися агностичною до моменту затвердження ТЗ.
6. Загальні нефункціональні вимоги повинні міститися в цих політиках.
7. Технічні вимоги не повинні містити реквізитних частин сутностей і документів.
8. Технічні вимоги повинні містити перелік сутностей.
9. Технічні вимоги повинні містити перелік процесів.
10. Технічні вимоги повинні містити перелік прав та привілеїв.
11. Технічні вимоги доменної області повинні містити перелік процесів і їх кроків.
12. Технічні завдання повинні містити BPMN діаграми, верифіковані аналітиками.
13. Технічні завдання повинні містити реквізитні частини сутностей і документів.
14. Технічне завдання повинно містити перелік ролей і ABAC правил.
15. Технічне завдання повинно містити перелік словників.
16. Технічне завдання повинно містити перелік протоколів взаємодії.
17. Технічне завдання повинно містити перелік шаблонів.
18. Будь-яка інформація, що дублюється в похідних документах повинна міститись тут.
19. Технічна документація повинна визначатись стандартами ISO і ДСТУ.
20. Технічне завдання повинно містити продукти, які підтримують стандарти ISO або ДСТУ.

2. Технічні вимоги

2.1. Перелік технічних вимог наведених в політиках

- Функціональні вимоги до словникової системи
- Функціональні вимоги до набору облікових сутностей і їх операцій
- Функціональні вимоги до набору валідацій
- Функціональні вимоги до рольової моделі
- Функціональні вимоги до інтерфейсу користувача
- Функціональні вимоги до системи процесів
- Нефункціональні вимоги до архітектури
- Нефункціональні вимоги до безпеки
- Нефункціональні вимоги до потужності та ємності
- Нефункціональні вимоги до системи логування
- Нефункціональні вимоги до інтерфейсу користувача
- Нефункціональні вимоги до контролю якості
- Нефункціональні юридичні вимоги

2.2. Повний зміст технічних вимог

Структура технічних вимог узагальнена для будь-якого високотехнологічного державного ПЗ.

- Умовні скорочення та визначення
- Загальні відомості
 - Передумови
 - Питання, що вирішуються
 - Вимоги законодавства та міжнародних стандартів (ДСТУ, ISO, NIST, ITU-T)
- Призначення та цілі впровадження
- Класифікація вимог
 - 3.1. Функціональні вимоги
 - * 3.1.1. Опис довідників
 - * 3.1.2. Опис реєстрових сутностей та їх станів
 - * 3.1.3. Опис бізнес-процесів (BPMN)
 - * 3.1.4. Вимоги до протоколів взаємодії
 - * 3.1.5. Опис прав та привілеїв (ABAC/RBAC/ACL)
 - * 3.1.6. Опис валідацій
 - * 3.1.7. Шаблони сповіщень
 - * 3.1.8. Вимоги до серіалізації
 - * 3.1.9. Вимоги до транспорту
 - 3.2. Нефункціональні вимоги
 - * 3.2.1. Вимоги до архітектури
 - * 3.2.2. Вимоги до безпеки
 - * 3.2.3. Вимоги до потужності і ємності
 - * 3.2.4. Вимоги до функціональності логування
 - * 3.2.5. Адміністративні вимоги
 - 3.2.5.1. Настанова до видів тестування
 - 3.2.5.2. Вимоги до настанов адміністратора
 - 3.2.5.3. Вимоги до документування
 - 3.2.5.4. Технологічний стек (агностичний опис)
 - * 3.2.6. Загальні вимоги до документації та артефактів
 - * 3.2.7. Юридичні вимоги

3. Технічне завдання

Структура технічного завдання відповідає ДСТУ 3973-2000 «Система розроблення та постачання продукції на виробництво. Правила виконання науково-дослідних робіт. Загальні положення» та ДСТУ 3974-2000 (для конструкторських робіт).

3.1. Зміст технічного завдання

ДСТУ 3973-2000 визначає зміст технічного завдання.

1. Мотивація, мета, виконавці
2. Класифікація вимог (функціональні, нефункціональні, технічні, адміністративні, ергономічні, політичні, юридично-правові, документальні, архітектурні)
3. Принципові вимоги (відповідність ДСТУ, NIST, ISO, ITU-T, ДССЗІ)
4. Функціональні вимоги
5. Ергономічні вимоги
6. Технічні вимоги
7. Адміністративні вимоги
8. Політичні вимоги
9. Юридично-правові вимоги
10. Документування (перелік документів)
11. Етапи виконання
12. Результати
13. Порядок передачі

3.2. Вимоги до Технічних завдань

3.2.1. Правила-рекомендації до ТЗ

- Продовження технічних вимог. Технічне завдання має бути продовженням технічних вимог. Кожна вимога, або група вимог визначена на рівні технічних вимог, повинна бути відображена в ТЗ, деталізована та пов'язана з конкретною функціональністю. Має забезпечуватися простежуваність від початкової потреби до реалізації, тестування та приймання результату + зв'язок із сутностями.
- Людиноцентричний підхід. Розробка має ґрунтуватися на людиноцентричному підході.
- Підтверджені потреби користувачів. Функціональність повинна створюватися для вирішення підтверджених потреб конкретних груп користувачів. Користувацькі сценарії, прототипи та дизайн-рішення мають перевірятися з реальними представниками відповідних ролей до завершення розробки.
- Контекст бізнес-процесів. Функціональність необхідно описувати в контексті бізнес-процесів. Для кожного рішення має бути зрозуміло, який процес або його конкретний крок воно підтримує, хто бере участь у процесі, з чого він починається та який результат повинен бути отриманий.

- Розкриття через Use Case. Ключова функціональність має розкриватися через use case. Сценарії використання повинні показувати взаємодію користувача, системи та інших учасників для досягнення визначеної мети. Рівень деталізації має залежати від складності, ризику та критичності функціональності.
- Альтернативні та негативні сценарії. Use case повинні охоплювати не лише основний успішний сценарій. Необхідно враховувати суттєві альтернативні, негативні та виняткові сценарії, зокрема помилки користувача, відсутність даних, недоступність інтеграцій, повторне виконання дій та відновлення процесу.
- Визначення бізнес-правил у BPMN. У межах кожного use case мають бути явно визначені бізнес-правила, які керують відповідним сценарієм. До них належать умови перевірки даних, маршрутизації процесу, застосування строків, розрахунків, ролей, обмежень і прийняття рішень. Такі правила не повинні самостійно визначатися розробником під час реалізації. За потреби для них зазначаються джерело, умови застосування та винятки.
- Явне визначення бізнес-правил. Бізнес-правила мають бути визначені явно. Правила перевірки, маршрутизації, строків, розрахунків, ролей і прийняття рішень не повинні формуватися розробником самостійно під час реалізації. Для критичних правил мають бути визначені їх джерело, умови застосування та винятки.
- Критерії приймання. До початку розробки потрібно визначити критерії приймання. Для кожної функціональності має бути зрозуміло, який результат очікується та за якими об'єктивними ознаками буде перевірятися його відповідність вимогам.
- Definition of Done. Окремо має бути визначений Definition of Done. Він повинен встановлювати спільний мінімальний стандарт завершеності: реалізація функціональності, виконання критеріїв приймання, тестування, документування, перевірка безпеки, доступності, інтеграцій та усунення критичних дефектів.
- Перевірка відповідності та цінності. Результат необхідно перевіряти як на відповідність ТЗ, так і на реальну цінність. Важливо підтвердити не лише те, що функціональність реалізована відповідно до опису, а й те, що вона працює в реальному процесі, вирішує початкову проблему користувача та може бути безпечно впроваджена й масштабована.

4. Посилання на стандарти ДСТУ

Стандарт	Назва та призначення
ДСТУ 3973-2000	Система розроблення та постачання продукції. Правила виконання науково-дослідних робіт. Загальні положення (основа структури ТЗ)
ДСТУ 3974-2000	Правила виконання науково-конструкторських робіт
ДСТУ 42010:2018	Інженерія систем і програмних засобів. Опис архітектури
ДСТУ 62264:2019	Інтеграція систем управління підприємством і виробництвом
ДСТУ 3008:2015	Документація на розроблення ПЗ
ДСТУ 3396.0-96, 3396.1-96, 3396.2-97	Комплекс стандартів на уніфіковану систему документації
ДСТУ 4541, ДСТУ 28147	Криптографічні стандарти України
ДСТУ 19.403–19.781, ДСТУ 34.003, 34.201, 34.601–34.602	Застарілі, але обов'язкові для сумісності стандарти документування

5. Функціональні вимоги

5.1. Вимоги до процесів системи

Система повинна буди ізоморвна моделі FSM (Finite State Machines), BPMN (ISO 19510), або Мережам Петрі, тобто повинна підтримувати паралельні і послідовні обчислення (погодження) необхідні для орагіназації документообігу. Визначення процесу, як сутності, що складається з наступних частин (як приклад такої ізоморфної системи):

- Контекст процесу у вигляді переліку документів
- Перелік станів процесу, кожен з яких є робочим місцем користувача або сервісом
- Переходи між станами що є функціями з логікою
- Початковий і кінцевий стани процесу
- Історія кроків процесу з документами

Кожен користувач визначається як сутність, що містить наступні реквізити:

- Сертифікат доступу КЕП Х.509
- ЄДРПО підприємства
- Посада, ПІБ, табельний номер
- Визначені ролі

Система бізнес-процесів повинна формально визначати:

- Перелік користувачів і структури підприємства
- Перелік ролей
- Перелік реєстрових сутностей, їх реквізитів і операцій над ними
- Перелік документів і їх реквізитів
- Перелік інформаційних повідомлень і їх реквізитів
- Перелік бізнес-процесів

5.2. Вимоги до викликів API

Для початку розробки аналітик замовника передає вендору зазначені верхньорівневі вимоги до методу. Після завершення розробки вендор надає опис методу за затвердженим шаблоном відповідно до настанови. Документація по опису методів API повинна бути створена згідно з затвердженими шаблонами.

- призначення методу: яку дію він має виконувати;
- формулювання методу: метод та ендпойнт;
- які параметри необхідні для виклику методу — початкові умови для застосування методу (параметри мають бути представлені у формі таблиці із зазначеним типом та прикладом формулювання);
- відповідь сервера у формі структурованих даних — інформація у форматі серіалізації (зразок відповіді описують у формі коду);
- обробка помилок: опис ситуації, коли виконання дії неможливе з певних причин (перелік помилок мають бути представлені у формі таблиці з розшифровкою значення);
- додаткова інформація: обмеження доступу, використання стандартів тощо (може бути представлена у формі довільного тексту в окремому розділі).

5.3. Вимоги до інтерфейсу користувача

5.3.1. Обробка помилок

Інтерфейс користувача має представляти чіткі та інформативні повідомлення про помилки із зазначенням їхньої причини та шляху виправлення. Інтерфейс користувача має надавати можливість повторної спроби операцій після усунення факторів, які спричинили помилку.

5.3.2. Загальні вимоги

Інтерфейс користувача має відповідати наступним загальним вимогам:

- Відповідність стандартам вебдоступності (WCAG): Забезпечення доступності для користувачів з обмеженими можливостями (наприклад, підтримка клавіатурної навігації, альтернативний текст для зображень, достатній контраст кольорів). Відповідність принаймні рівню AA стандартів WCAG 2.1.
- Наслідування дизайн-коду компанії: Інтерфейс має відповідати існуючому дизайн-коду компанії (стиль, кольори, шрифти, логотипи тощо). Використання компонентів UI з бібліотеки компонентів компанії (якщо така є для певного функціоналу). Забезпечення консистентності візуального стилю між різними частинами системи.

6. Нефункціональні вимоги

6.1. Вимоги до архітектури

Перший підрозділ описує загальну архітектуру ERP/1, та вимоги до розробників додаткової функціональності. Ця глава визначає карту вимог та описує загальний перелік вимог, який впливає з логіки розгортання архітектурних рівнів ISO-42010.

6.1.1. Визначення термінів і призначення документа

Архітектура тут і надалі буде означати формальний структурний опис компонент і регламентів взаємодії з розширеною деталізацією прикладного рівня.

Призначення документа:

- ознайомити виконавця з поточною архітектурою ERP/1;
- визначити технології, які існують й використовуються в ERP/1;
- визначити вимоги та обмеження реалізації.

6.1.2. Рівні архітектури компонентів системи

За основу взята архітектурна методологія ISO/IEC/IEEE 42010 та фреймворк Закмана.

1. Компоненти архітектури ERP/1 є цілком визначеними та узгодженими.
2. Контрактори, які реалізують проєкт нової функціональності ERP/1 повинні зазначити на наступних архітектурних рівнях які модифікації потребує система:
 - Сутності (Resources, ER-діаграми);
 - Форми (Forms, містять додаткову інформацію для UI);
 - Валідації (Validations);
 - Процеси (Послідовність використання API, BPMN діаграми);
 - Довідники (Dictionaries);
 - Права (Scopes);
 - Функції сервісів (публічні та приватні) (Functions, API, RPC);
 - SQL-таблиці;
 - KV-простори;
 - Cache-простори;
 - Правила обмеження швидкості засобами KONG (Rate limiters).
3. Перелік модифікацій повинен надаватися в формі, де кожна зміна зазначена у відповідному документі-вимозі до оформлення кожного архітектурного рівня. В цьому контексті вимоги до опису архітектури є кореневим документом-вимогою який описує зміни до архітектури ERP/1 на верхньому архітектурному рівні.

6.1.3. Маніфест відповідності архітектурі ERP/1

Мотиваційна частина: мета документу.

1. Стандартизація та уніфікація функцій ПЗ повинна бути забезпечена за рахунок використання сучасних інструментальних програмних засобів, які підтримують єдину технологію проектування і розробки функціонального, інформаційного та програмного забезпечення.
2. ПЗ в цілому та інші програмні компоненти повинні відповідати основним міжнародним та національним угодам і стандартам в галузі інформаційних технологій.
3. Необхідно використовувати вже наявні у Замовника системи та програмне забезпечення.
4. Версії систем і підсистем продуктів повинні відповідати версіям, що використовуються.
5. Нове технічне забезпечення (наприклад, підсистеми) має відповідати наступним вимогам:
 - безкоштовність нової системи/підсистеми, її залежностей, і їх ліцензій;
 - наявність підтримки розробника (1 рік від останньої версії);
 - програмне забезпечення з відкритим вихідним кодом (open source).
6. Вимоги стосуються безпосередньо і програмного забезпечення, розробку якого сплачує Замовник.
7. Будь-яке інше програмне забезпечення повинно відповідати вимогам.
8. Вимоги до горизонтального масштабування (за необхідності). Шардінг, контейнеризація, оркестрація.
9. Балансування навантаження між декількома екземплярами сервісів (подами).
10. Використання черг для часомістких операцій.
11. Мінімізація розміру інформаційних повідомлень і оптимізація трафіку.
12. Вимоги до телеметрії, кількість операцій за секунду, латенсі, помилки, статуси.
13. Вимоги до потужності і ємності.
14. Вимоги до логування.
15. Можливість проведення автоматичного тестування з відключеними сервісами КЕП.
16. Мінімізація вартості володіння.

6.1.4. Структура продуктів ERP/1

Корпоративні продукти

- Освіта — Автоматизована інформаційна система управління освітнім процесом ISO 21001, навчальною діяльністю та адмініструванням закладів освіти з підтримкою очної, дистанційної та змішаної форм навчання.
- Здоров'я — Медична інформаційна система HL7 для автоматизації обліку медичних послуг та управління медичною інформацією в електронному вигляді.
- Документи — Автоматизація роботи з електронними документами у вигляді CRM системи згідно інструкції з діловодства №40 від 2024 року.
- Облік — Комплексна ERP система автоматизації бухгалтерського обліку, кадрового діловодства та розрахунку заробітної плати для підприємств і державних установ.
- Склад — Автоматизована система управління складським господарством та матеріально-технічним забезпеченням підприємств і державних установ.
- Реєстри — Універсальна платформа для створення, ведення та управління державними, відомчими та корпоративними інформаційними реєстрами будь-якого масштабу.

Системні продукти (Платформа)

- Сертифікати — Центр сертифікації реєстраційних посвідчень і їх ABAC реквізитної атрибутики для інфраструктури PKI.
- Тунелі — Високопродуктивна система побудови захищених децентралізованих тунелів (L2/L3) на базі віртуальної машини Erlang/OTP.
- Директорія — PKI-aware LDAP з підтримкою X.500.
- Комунікатор — TLS X.690 DER сервер v1+, v2 і v3 протоколів і ПК КЗІ X.509 v1 протоколу BUDDHA.
- Процеси — Процесний BPMN рушій ISO 19510 для бізнес-логіки з TLS X.690 DER інтерфейсом.
- Брокер — MQTT v5.0 сервер персистентних топіків стандарту ISO/IEC 20922:2016, що використовується в продуктах SYNRC.
- Сховище — Бібліотека KVS, що реалізує SNIA інтерфейс для NVMe дисків, сумісна з RocksDB та CEPH.
- Фреймворк — N2O/NITRO фреймворк для розробки веб-додатків.
- Форми — Бібліотека X-FORM для відображення реквізитної інформації та автоматичної генерації клієнтських і серверних валідацій.
- Компілятор — ASN.1 X.680 компілятор для мов програмування ANSI C99 та Apple Swift.
- Контроль — Бібліотека ABAC для контролю доступу на рівні реквізитної інформації документів та їх сертифікатів.

6.1.5. Таксономія системних компонент

Перелік категорій компоненти згідно з класифікацією по їх функціональним категоріям (в дужках зазначені приклади які згодом можливо зафіксуються в технічному завданні).

- Data Storages (Приклади: MongoDB, SQL, S3, Cassandra, Riak, tikv);
- PubSub Buses (Приклади: Kafka, MQTT, AMQP);
- Application Services (Приклади: D3, ERP/1, CRM);
- Facade Management (Приклади: Traefik / KONG); OSI Layer 4—7;
- Virtual Machines (Приклади: JVM, CLR, BEAM);
- External Systems (Трембіта: ДССУ, Дія, ПФУ, Мініюст).

Види Data Storages:

- KV. Сховище з єдиним простором ключів для зберігання подій і документів.
- SQL. Реляційне сховище для обліку бізнес-сутностей.
- S3. Сховище медіа-об'єктів (документів, файлів, тощо) з Amazon S3 інтерфейсом.
- FS. IPFS, NTFS, SAMBA, GlusterFS, ZFS.

Види Pub/Sub Buses:

- MQTT. Брокер повідомлень, основа Service Oriented Architecture (SOA). ISO.
- AMQP. Теж. ISO. Не використовується зараз.
- XMPP. Теж. ISO.
- Kafka. Non-ISO.
- NSQ. Теж. Non-ISO.

Application Services:

- Anti Fraud. Сервіс блокування зловмисних дій.
- One Time Password. Сервіс верифікації через одноразові паролі.
- Authentication and Authorization. Сервіс аутентифікації і авторизації.
- Integration Layer. Основні сервіси і реєстри.
- Data Layer. Безпосередній доступ до реплік PostgreSQL.
- Digital Signature. Сервіс електронного підпису.
- Master Citizen Index (MCI). Сервіс ізоляції персональних даних користувачів.
- Extract, Transform, Load (ETL). Зовнішні конектори.

Web Frameworks:

- Основані на шаблонізаторах (PHP, Django DTL, Elixir EEX)
- Основані на DSL (PureScript, Ocsigen, LiveView, N2O, WebSharper, UrWeb, Flutter)
- Клієнтські REST фреймворки з інфраструктурою (vue.js, react.js)
- REST мікро-фреймворки
- WebSocket фреймворки

6.2. Вимоги до безпеки

Другий підрозділ описує загальні і технічні вимоги до інформаційної безпеки, що діє наскрізно на прикладному, презентаційному, сесійному і транспортному рівні моделі OSI.

6.2.1. Загальні вимоги до інформаційної безпеки

Додати вимоги для персональних даних, приналежність до кластерів.

1. Вимоги до інформаційної безпеки повинні відповідати:
 - закону України «Про захист інформації в інформаційно-телекомунікаційних системах»;
 - закону України «Про захист персональних даних»;
 - закону України «Про основні засади забезпечення кібербезпеки України»;
 - закону України «Про інформацію»;
 - правилам забезпечення захисту інформації в інформаційних, телекомунікаційних та інформаційно-телекомунікаційних системах, затвердженим Постановою Кабінету Міністрів України від 29.03.06 № 373;
 - порядку функціонування електронної системи охорони здоров'я, затверджене постановою Кабінету Міністрів України від 25.04.2018 № 411;
 - іншим нормативно-правовим актам, що регулюють питання захисту інформації, у тому числі в інформаційно-телекомунікаційних системах.
2. Виконавець має забезпечити функціональну можливість засвідчення даних, що вносяться до ERP/1 користувачами виключно за допомогою кваліфікованого електронного підпису (далі – КЕП):
 - в якому наявні атрибути **certificate-values** та **revocation-values**, які свідчать про CAdES-X Long формат довгострокового розширеного підпису КЕП;
 - що зберігається на захищеному апаратному носії.
3. Для підключення до ERP/1, виконання функцій формування / перевірки КЕП, для взаємодії з кінцевими користувачами в складі додатка мають використовуватись засоби криптографічного захисту інформації, які мають чинний позитивний експертний висновок за результатами державної експертизи у сфері криптографічного захисту інформації щодо можливості їх використання для криптографічного захисту конфіденційної інформації (персональних даних фізичних осіб).
4. Додаток повинен забезпечувати захист від вразливих компонентів, а саме:
 - усі компоненти, включаючи бібліотеки та плагіни, повинні регулярно перевірятися на наявність відомих вразливостей, зазначених в базі даних exploit-db (www.exploit-db.com/);
 - усі застарілі або вразливі компоненти повинні бути оновлені або замінені на безпечні аналоги не пізніше 5 робочих днів з дня виявлення;
 - система повинна бути налаштована таким чином, щоб уникати використання компонентів, які більше не підтримуються.
5. Додаток повинен забезпечувати захист від небезпечних налаштувань, а саме:
 - всі непотрібні функції та служби повинні бути вимкнені або видалені;
 - конфігураційні файли повинні бути захищені від несанкціонованого доступу і зберігатися в зашифрованому вигляді.
6. Додаток повинен забезпечувати захист від порушень управління доступом, а саме:

- доступ до всіх ресурсів повинен здійснюватися згідно з принципом найменших привілеїв;
- контроль доступу повинен бути централізованим і надавати права тільки тим користувачам, які мають на це необхідні підстави;
- необхідно вести журнал аудиту доступу до конфіденційних даних з можливістю перевірки дій користувачів, термін зберігання яких не менше 3 місяців.

7. Додаток повинен реалізовувати основні функції захисту:

- забезпечення періодичного резервного копіювання баз даних додатку;
- забезпечення однозначної ідентифікації та аутентифікації користувачів додатка;
- забезпечення захисту організаційними заходами від несанкціонованого доступу до інформації при її обробці засобами додатка;
- контроль за проходженням на мережевому рівні тільки дозволених інформаційних потоків з боку телекомунікаційних мереж до додатку, а також у зворотному напрямку (щонайменше, на рівнях L3, L4 моделі Open Systems Interconnections, OSI);
- забезпечення реєстрації подій, пов'язаних з отриманням користувачами доступу до ресурсів додатка (проходження/непроходження автентифікації), зміни налаштувань програмного забезпечення, серверів та комутаційного обладнання;
- забезпечення ведення журналів безпеки, усі важливі події безпеки, такі як спроби несанкціонованого доступу, повинні бути зафіксовані у журналах безпеки. Журнали повинні зберігатися не менше 3 місяців, в захищеному вигляді та бути недоступними для модифікації неавторизованими користувачами;
- забезпечення конфіденційності та цілісності інформації з обмеженим доступом, що передається каналами зв'язку через незахищене середовище.

8. Заборонено використовувати проміжні інтерфейси авторизації користувачів, крім веб-сторінки авторизації.

9. Інформаційна безпека додатка має обов'язково відповідати 10 найбільш важливим перевіркам на безпеку (TOP 10), які розміщуються в інформаційному онлайн-документі для розробників і тестувальників з безпеки додатків The Open Worldwide Application Security Project (OWASP).

6.2.2. Технічні вимоги до інформаційної безпеки

1. Додаток повинен мати відкритим лише порт 443 для безпечного HTTPS-з'єднання. Інші порти повинні бути закриті.
2. Додаток повинен використовувати чинний SSL/TLS сертифікат, що видається лише довіреним органом сертифікації.
3. Додаток повинен використовувати SSL/TLS сертифікат, який відповідає криптографічним стандартам ECC (ECDSA) або RSA (DSA, з 2048-бітними ключами, дозволеними до 2030 року згідно з нормативами NIST).
4. Додаток повинен забезпечувати захист від SQL-ін'єкцій й використовувати екранування спецсимволів: ' (0027), " (0022), \ (005c), - (002d002d), % (0025), /* */ (002f002a, 002a002f), # (0023), & (0026), _ (005f), \n (005c006e), \r (005c0072), \t (005c0074), %00.
5. Додаток повинен забезпечувати захист від вразливостей автентифікації та керування сесіями, а саме:
 - сесійні токени повинні зберігатися у cookie з прапорами **Secure** та **HttpOnly**;
 - заборона одночасної сесії (сеансу) користувачів на різних пристроях.
6. Додаток повинен забезпечувати захист від XSS-ін'єкцій, а саме:
 - додаток повинен використовувати тільки безпечні заголовки (CSP, HTTPOnly, X-XSS-Protection, X-Frame-Options, HSTS) для запобігання доступу клієнтських сценаріїв до даних;
 - при внесенні користувачем даних в інтерфейсі додаток повинен попередити користувача та не дозволити ввести символи та конструкції (що заповнюються в полях), які можуть бути використані для впровадження скриптів або зміни URL, такі як: javascript:, vbscript:, data:, onclick, onload, onsubmit, ? (003f), ' (0027), " (0022), & (0026), < та > (003c 003e), \n (005c006e), \r (005c0072), \t (005c0074), %00, /* */ (002f002a, 002a002f), NULL та # (0023).
7. Додаток повинен забезпечувати захист від виконання довільного коду (Command Execution), наприклад, eval(), exec(), або shell_exec().
8. Додаток повинен використовувати протокол "Transport Layer Security (далі – TLS)" версії не нижче 1.3, що відповідає вимогам чинного законодавства.

6.3. Вимоги до потужності та ємності

Цей підрозділ визначає процес аналізу та валідації вимог до потужності і ємності нової функціональності, що є одними з головних технічних ризиків при проєктуванні інформаційних систем.

1. Програмний код повинен бути сумісний з горизонтальним масштабуванням процесингових обчислень, щоб динамічно збільшувати ємність системи як лінійну залежність від кількості екземплярів процесингових обчислень.
2. Програмний код має автоматично підтримувати одночасне виконання багатьох невеликих процесів (concurrent) та працювати паралельно на кількох ядрах (parallel).
3. У випадку релізу, який додає функціональність і/або змінює flow по роботі з наявним, слід планувати проведення навантажувального тестування з метою визначення впливу на продуктивність системи на середовищі Stage.
4. Програмне забезпечення, що реалізується, повинно відповідати наступним критеріям:
 - Первинне джерело даних, на базі яких проводиться аналіз ризиків потужності та ємності;
 - Якщо аналітичних даних недостатньо, то прогнозування навантаження повинно відбуватися на основі дотичних сервісів;
 - Після прийому релізу відділ контролю якості перевіряє виконання вимог до потужності шляхом навантажувального тестування, який передбачає також взаємодію з відділом супроводу і підтримки.
5. Продуктивність або потужність підсистем визначається наступним набором характеристик (таблиця, яка заповнюється бізнес-аналітиками на основі прогнозованих значень):
 - час реакції (активація асинхронної задачі);
 - пропускна здатність (кількість виконаних задач за одиницю часу);
 - затримка передачі (latency, час приходу першого байту від асинхронної чи синхронної відповіді).

6.3.1. Таблиця характеристик продуктивності

Характеристика	Опис	Прогноз
Час реакції	Активація асинхронної задачі	< 200 мс
Пропускна здатність	Кількість виконаних задач за одиницю часу	500 задач/с
Затримка передачі (latency)	Час приходу першого байту відповіді	< 150 мс

6.4. Вимоги до системи логування

6.4.1. Загальні вимоги

1. Змістовність. Кожне повідомлення в логах повинно містити цінну інформацію.
2. Цілісність. Логи повинні утворювати логічний ланцюжок подій, що призвів до проблеми.
3. Відтворення проблем. Логи повинні містити достатньо інформації для відтворення проблеми на середовищі розробника.
4. Роздільність. Кожен сервіс повинен мати власний лог.
5. Лаконічність. Логи повинні бути читабельними та не містити зайвої інформації.
6. Захист даних. Приватні та персональні дані (логіни, паролі, секретні ключі, персональні дані клієнтів) не повинні зберігатися в логах в явному вигляді. Використовуйте хешування.
7. Метрики та статистика. Логи повинні дозволяти побудувати метрики, статистику швидкодії та продуктивності додатка і його компонентів.
8. Історія подій. Логи повинні містити історію подій до моменту виникнення помилки без потреби запитувати користувачів.
9. Логуювання помилок. Логи помилок повинні бути пов'язані з усіма попередніми повідомленнями, що стосуються процесу або запиту. Повідомлення мають бути доступні для пошуку за унікальним ідентифікатором.
10. Логуювання змін. Будь-які зміни в конфігурації додатка та його компонентів повинні бути залоговані.
11. Структуровані логи. Логер повинен бути структурованим і логувати інформацію в форматі JSON.

6.4.2. Рівні логуювання

Рівні логуювання мають керуватись на рівні конфігурації додатку. Вмикаючи в конфігурації системи один з рівнів логуювання, також будуть залоговані й повідомлення нижчих рівнів. Наприклад, увімкнувши рівень `information`, ви матимете записи логів `warning`, `error`, `critical`.

1. Trace. Логуються всі властивості об'єктів, параметри методів, виклики методів та виконання кожного рядка коду. Використовується тільки в середовищі розробки/тестування.
2. Debug. Логуються системні параметри, запити до джерел даних, виклики методів. Використовується на продуктивному середовищі на короткий час для діагностики.
3. Information. Логуються події, такі як запуск/зупинка компонентів.
4. Warning. Логуються підозрілі або некритичні позаштатні ситуації.
5. Error. Логуються події, що переривають поточні операції, але не впливають на подальшу роботу системи.
6. Critical. Логуються критичні помилки, що перешкоджають подальшій роботі системи (наразі в системі помилка відсутня).

6.4.3. Інформація для вендорів про інструментарії логування

1. Filebeat:
 - потрібно використовувати для збору логів з усіх джерел;
 - повинен бути налаштований на надсилання даних до Elasticsearch.
2. Logstash:
 - має забезпечувати обробку логів з можливістю трансформації, фільтрації та агрегації даних;
 - конфігурації повинні бути задокументовані та доступні.
3. Elasticsearch:
 - логи повинні зберігатися в Elasticsearch для швидкого пошуку та доступу;
 - необхідно забезпечити належну масштабованість та продуктивність системи.
4. Kibana:
 - має використовуватися для візуалізації та аналізу збережених логів;
 - потрібно забезпечити можливість створення графіків та дашбордів для моніторингу.

6.4.4. Події логування

1. Запуск/зупинка окремих сервісів системи.
2. Події безпеки типу звернення системи до сервісів системи.
3. Помилки у роботі системи, таких як комунікаційні, цілісності даних у системі, непередбачувані затримки в обробці інформації.
4. Критичні події від системи моніторингу (критичний обсяг пам'яті, дискового простору тощо).
5. Інші події безпеки.

6.4.5. Структура журналу логування

Структура журналу логування повинна включати:

1. Ідентифікатор запиту в наборах відкритих даних, на який надається відповідь.
2. Дата та час запиту.
3. Результат обробки запиту.
4. Ідентифікатор відповіді від набору відкритих даних, щодо якого надається повідомлення.
5. Дата та час створення відповіді.
6. Набір вхідних параметрів.
7. Час виконання.

6.4.6. Вимоги до структурних логів ELK стеку

Лог має бути представлений у форматі JSON об'єкта з наступними визначеними полями:

- `time` — log time
- `severity` — log level (DEBUG, INFO, WARNING, ERROR)
- `log` — log message

Додатково включати по наявності наступні поля, якщо присутні такі метадані:

- `source_location.file`
- `source_location.line`
- `source_location.module`
- `source_location.function`
- `error.initial_call` — `"#{module}.#{function}"` або `"#{module}.#{function}/#{arity}"`
- `error.reason` — `"#{module}.#{function}"` або `"#{module}.#{function}/#{arity}"`

Додатково можна включати інші поля за необхідності.

6.5. Вимоги до контролю якості

6.5.1. Загальні вимоги до обліку і контролю якості

Види тестувань:

- Внутрішні тести розробників.
- Ручне тестування за допомогою Postman, curl, wscat, тощо.
- Автоматичне регресивне тестування з використанням кваліфікаційного електронного підпису.
- Навантажувальне тестування.

Тестувальна документація має трактувати кроки, терміни та результати тестування. Склад документації з тестування залежить від конкретної задачі, але повинен містити:

- Об'єкт тестування. Необхідно чітко визначити, який об'єкт тестування підлягає приймальному тестуванню (модуль, програмне забезпечення, веб-додаток, мобільний додаток або комплексна система). Вказати конкретну функціональність та компоненти.
- Критерії успішності. Критерії, які повинні бути виконані для визнання тестування успішним (функціональні вимоги, продуктивність, стабільність, безпека, сумісність тощо).
- Сценарій тестування. Опис тестового середовища, набір сценаріїв тестування та покрокових процедур (тест-кейси).
- Умови тестування. Конфігурації системи, вхідні дані, налаштування, середовища виконання тощо.
- План тестування. Документ, що описує весь обсяг робіт із тестування.
- Критерії прийняття. Кількість та тип прийнятних дефектів, виконання функціональностей, бізнес-сценаріїв тощо.
- Протоколи результатів тестування. Загальна оцінка (успішно/неуспішно), вплив тестового середовища, результати кожного тест-кейсу.
- Стратегія контролю версій. Контроль та управління версіями документів, які використовуються в тестуванні.
- Вимоги до навантаження та продуктивності. Обсяги даних, кількість одночасних користувачів, транзакцій, очікувані показники продуктивності та час відповіді.
- Звітність та документування. Формат звітів, структура, висновки та рекомендації.

6.5.2. Вимоги до ручного тестування

Ручне тестування повинно оцінювати функціональність з точки зору звичайного користувача та надавати максимально розгорнутий і зрозумілий звіт. Необхідно виконати перевірку:

- форм користувача (коректне заповнення, виведення помилок, обов'язкові/необов'язкові поля, календарі, меню тощо);
- посилань та навігації сайту;
- форм реєстрації та авторизації;
- роботи з базою даних (додавання, редагування, видалення даних, завантаження файлів);
- файлів cookie;
- пошукового рядка.

Необхідно виконати перевірку нетипових сценаріїв для виявлення несподіваних помилок і багів.

Перевірка безпеки:

- Конфіденційність (обмеження доступу до особистих даних);
- Цілісність (можливість відновлення інформації після атаки);
- Доступність (розмежування рівнів доступу).

Оцінка дизайну:

- Простота експлуатації;
- Зручність навігації;
- Відповідність контенту (шрифти, кольори, розташування елементів);
- Мінімальна кількість кліків для виконання операцій.

Тестування на сумісність:

- На різних пристроях (ПК, планшет, телефон) та ОС (Windows, macOS, Android);
- У різних браузерах (Edge, Firefox, Chrome, Safari, Opera).

Тестування продуктивності

- Навантажувальне тестування;
- Стрес-тестування;
- Об'ємне тестування;
- Тестування надійності.

Необхідно виконати регресивне тестування після внесення змін у код. Функціональні вимоги до HTTP API тестування:

- Правильність відповідей та використання коректних HTTP-статус-кодів
- Валідація вхідних даних (формати, обов'язкові поля, медичні коди)
- Захист від помилок та чіткі повідомлення про помилки
- Правильний формат даних у відповідях
- Перевірка обов'язкових полів.

Вимоги до специфікацій технічної документації: Технічна документація повинна містити:

- Архітектурний опис системи та взаємодії компонентів
- Опис модулів та функцій

- API-специфікацію (ендпоінти, методи, запити, відповіді, статуси)
- Опис бази даних (схема, таблиці, зв'язки);
- Опис інтерфейсу користувача (wireframes, прототипи, адаптивність)

6.5.3. Вимоги до формату сценаріїв та протоколів тестування

Сценарії надаються у вигляді таблиці у полях «Від замовника» та «Від виконавця» вказується ПІБ. Зазначаються дати надання та виконання сценаріїв. Протокол тестування формується у вигляді звіту Jira або у форматі XLS/DOCX. Протокол повинен містити:

- Найменування системи та номер версії;
- Назву тестового середовища;
- Перелік виконаних тест-кейсів.

Для кожного тест-кейсу вказується:

- Назва тест-кейсу;
- Статус;
- Дата виконання;
- ПІБ тестувальника;
- Перелік незакритих дефектів;
- Підсумковий висновок.

Табл. 3: Шаблон протоколу тестування

ІД сценарію	
Назва сценарію	
ІД тестового випадку	
Передумови	
Кроки відтворення / Умови	
Очікуваний результат	
Статус	
Коментар	
Дата тестування	
Тестувальник	
Від замовника	
Від виконавця	

6.5.4. Вимоги до плану тестування

Перед початком тестування функціональності має бути підготовлено план тестування. План тестування — це документ, в якому визначені об'єми, ресурси та календарний план тестування. Визначається відділом контролю якості. План тестування повинен містити наступну інформацію:

- Об'єкт тестування. Назва проекту або компонента, який підлягає тестуванню.
- Мету тестування. Виявлення дефектів, перевірка функціональності, валідація вимог, оцінка продуктивності тощо.
- Стратегія тестування. Типи тестів: модульне, інтеграційне, системне, регресійне, продуктивності, безпеки тощо.
- Обсяг тестування. Кількість тестових сценаріїв, наборів даних, ітерацій, тривалість тестового циклу.
- Ресурси тестування. Людські ресурси, апаратне та програмне забезпечення, тестові середовища, тестові дані.
- Графік тестування. Дати початку та закінчення тестового циклу, терміни проведення окремих видів тестів.
- Ризики тестування. Ідентифікація, оцінка ризиків та заходи щодо їх зниження.
- Критерії прийняття. Умови прийняття системи після тестування.
- Відповідальності та ролі. Ролі та відповідальності учасників тестування (тестувальники, керівники проекту, розробники тощо).

6.5.5. Вимоги до автоматичного тестування

Вся функціональність сервісу повинна бути повністю покрита автоматичними тестами.

Виконавець зобов'язаний надати документацію, яка містить:

- Об'єкт автотестування;
- Мету автотестування;
- Типи тестів та сценарії;
- Використовувані фреймворки та інструменти;
- Критерії успішності;
- Інтеграцію в процес CI/CD;
- Описи тестів, підготовку тестових даних, передумови та очікувані результати.

6.5.6. Вимоги до результатів приймального (UAT) тестування

Приймальне (UAT) тестування має бути виконано на Демо-середовищі (якщо інше не погоджено з Замовником). Замовник затверджує висновок про відповідність функціональності вимогам технічного завдання згідно з таблицею 5.5.1. Після успішного UAT Виконавець передає поставку програмного забезпечення для інсталяції та налаштування на середовищах Замовника. Прийняття функціональності можливе повністю або частинами згідно з календарним планом. Функціональність має бути прийнята Замовником в повному обсязі згідно з календарним планом виконання робіт.

6.6. Вимоги до інтерфейсів

Даний підрозділ визначає ергономічні та технічні вимоги до інтерфейсів користувача адміністративних панелей.

6.6.1. Загальні вимоги

Інтерфейс користувача адміністративної панелі є критичним елементом для ефективного управління та адміністрування програмного забезпечення чи веб-сайту.

- Інтуїтивність та простота. Інтерфейс повинен бути легким для використання, навіть для користувачів без глибоких технічних знань.
- Логічна структура та навігація. Забезпечення логічної організації елементів та легкої навігації між різними функціями та розділами.
- Мобільна сумісність. Адаптивний дизайн для коректного відображення на різних пристроях, включаючи мобільні телефони та планшети.
- Гнучкість налаштувань. Можливість налаштування інтерфейсу відповідно до унікальних потреб та завдань адміністратора.
- Зручне управління даними. Легкість управління, внесення та вилучення даних з адміністративної панелі.
- Інформативність. Забезпечення користувача інформацією про стан системи, статистику та повідомлення про можливі проблеми.
- Безпека та авторизація. Захист інтерфейсу від несанкціонованого доступу, використання протоколів шифрування та можливість налаштування рівнів доступу.
- Інтеграція з іншими системами. Можливість інтеграції з іншими системами та сервісами.
- Спрощений процес розгортання та оновлення. Легкість встановлення та оновлення адмінпанелі для мінімізації перерв у роботі.
- Підтримка різних мов. Localize (продукт який використовується в кабінеті пацієнта).
- Підтримка технічних засобів. Забезпечення сумісності з різними веб-браузерами та операційними системами.

6.6.2. Вимоги до відображення інформації

- Кросбраузерність. Система має бути адаптованою для використання в усіх сучасних браузерах.
- Адаптація для людей з вадами зору. Інтерфейс має бути адаптований для людей з порушенням зору згідно з ДСТУ EN 301 549:2022 та рекомендацій WCAG 2.1 (W3C Web Content Accessibility Guidelines):
 - контрастні кольори;
 - вибір розміру шрифту.
- Адаптація до розмірів екрана на пристроях. Веб-сайт має бути адаптивним і коректно масштабуватися на екранах різного розміру.

6.6.3. Вимоги до швидкодії додатка

Швидкість завантаження та відображення табличних частин. Час повного завантаження таблиці з 2000 рядками повинен становити не більше 1 с, а відображення видимої частини повинна становити не більше 300 мс.

6.6.4. Вимоги до технології реалізації додатку

- Single Page Application. Використання наперед сформованих HTML-частин на стороні сервера і модифікація структури DOM-елементів в браузері відносно WebSocket.
- Data-on-Wire. Використання тільки даних між клієнтом і сервером, що вимагають розвинутої інфраструктури (шаблонізаторів і клієнтської шини повідомлень для графічних контрольних елементів) і мов програмування для об'ємних клієнтів.
- Figma. Артефакти додатку (assets) та/або демо-прототип UI/UX повинні надаватися в Figma.

6.7. Юридичні вимоги

6.7.1. Зміст

- Перелік юридичних документів, що входять до комплексу поставки та надаються в паперовому вигляді
 1. Договір про передання (відчуження) майнових прав інтелектуальної власності
 2. Акт прийняття-передання наданих послуг
 3. Акт приймання-передачі майнових прав на Комп'ютерну програму
 4. Договори з субпідрядниками (за наявності)
 5. Акт прийняття-передання по електронному носії інформації (опис електронного носія інформації)
- Вимоги до патентної чистоти
- Вимоги до розвитку та модернізації функціоналу
- Гарантійна (технічна) підтримка функціоналу
- Перелік юридичних документів
- Вимоги до передачі прав на інтелектуальну власність

На момент момент укладення договору щодо розроблення Системи Виконавець має врегулювати усі відносини з авторами та третіми особами, які залучаються ним до створення Системи, а також надати підтвердження виникнення у нього в майбутньому майнових прав на Систему та її компоненти:

1. Надати підтвердження укладення з авторами Системи та її компонентів договорів, предметом яких є створення на замовлення об'єктів права інтелектуальної власності. Умовами договорів має бути врегульовано питання щодо: (1) отримання замовлення (завдання) щодо створення Системи та її компонентів; (2) переходу права власності на результати виконаних робіт; (3) отримання авторської винагороди (у т. ч. паушальної) у зв'язку з передачею прав щодо використання без часових, предметних, кількісних та територіальних обмежень; (4) компенсацій та інших платежів за передачу майнових прав; (5) немайнових прав автора, зокрема права на внесення змін до твору; (6) оригінальності твору або отримання відповідних дозволів щодо створення похідних творів. Якщо Система та її компоненти будуть створюватися як службовий твір - надати підтвердження трудових відносин з авторами.

2. Врегулювати питання щодо оригінальності твору, а саме створення Системи та її компонентів з використанням інших об'єктів права інтелектуальної власності, які раніше не створювалися, або щодо отримання всіх прав на таке використання.

3. Врегулювати питання щодо відсутності будь-яких майнових чи немайнових вимог з боку інших осіб, для яких зазначена Система та її компоненти, створювалися раніше, або яким передавалися права на таку Систему та її компонентів, та забезпечити умови ексклюзивності.

4. Врегулювати інші питання, важливі для забезпечення переходу до держави в особі ДСА України всіх прав на Систему та її компоненти без часових, предметних, кількісних, територіальних чи інших обмежень.

Висновок

Дотримання принципу «політики → вимоги → технічне завдання» та обов’язкове використання ДСТУ гарантує технологічну незалежність, аудитованість та відповідність державним нормам. Конкретні продукти обираються лише на етапі технічного завдання.

Література

- [1] Міністерство охорони здоров’я України. Технічні вимоги Реабілітація 2.0. Версія 08.08.2024.
- [2] ДСТУ 3973-2000. Система розроблення та постачання продукції на виробництво. Правила виконання науково-дослідних робіт. Загальні положення.
- [3] ДСТУ 3974-2000. Система розроблення та постачання продукції на виробництво. Правила виконання науково-конструкторських робіт. Загальні положення.
- [4] ДСТУ 42010:2018. Інженерія систем і програмних засобів. Опис архітектури.
- [5] Закон України «Про захист інформації в інформаційно-телекомунікаційних системах».
- [6] Закон України «Про захист персональних даних».
- [7] Закон України «Про основні засади забезпечення кібербезпеки України».
- [8] OWASP Foundation. OWASP Top 10: The Ten Most Critical Web Application Security Risks. <https://owasp.org/www-project-top-ten/>.
- [9] NIST Special Publication 800-57 Part 1 Revision 5. Recommendation for Key Management.
- [10] ISO/IEC/IEEE 42010:2022. Systems and software engineering — Architecture description.
- [11] Zachman, J.A. A Framework for Information Systems Architecture. IBM Systems Journal, 1987.